

VibeSecSys Security Report

Summary of Findings

Three hosts were discovered with a total of **28 open ports** across a wide range of services.

192.168.56.20

This host is the most exposed and appears to be a **high-risk, likely intentionally vulnerable system** or poorly hardened server. It exposes many administrative, legacy, and database services, including:

- **Remote access:** SSH, Telnet, VNC, X11
- **File sharing:** FTP, NFS, SMB/NetBIOS
- **Databases:** MySQL, PostgreSQL
- **Mail/DNS/Web:** SMTP, DNS, HTTP
- **Remote execution / legacy services:** exec, login, rpcbind, Java RMI, bindshell, AJP13, IRC

This concentration of services significantly increases the attack surface.

192.168.56.30

This host has only:

- SSH
- HTTP

This is comparatively minimal and likely a standard Linux host or web server, though still requiring verification of hardening and patching.

192.168.56.50

This host exposes:

- MSRPC
- NetBIOS-SSN
- Microsoft-DS (SMB)

This is consistent with a **Windows system or Samba file-sharing host**, and indicates possible exposure of SMB-related attack surface.

Risks Identified

1. Excessive attack surface on 192.168.56.20

The number and variety of open ports substantially increase exposure to:

- brute-force attacks
- remote code execution
- credential theft

- unauthorized file access
- service-specific exploits

2. Use of insecure/legacy protocols

Several services are inherently insecure or obsolete:

- **Telnet (23)**: transmits credentials in plaintext
- **FTP (21, 2121)**: plaintext authentication and data transfer unless explicitly secured
- **exec/login (512, 513)**: legacy remote shell services, insecure by design
- **X11 (6000)**: often insecure if not tightly controlled
- **r services / rpcbind / NFS**: frequently abused if misconfigured

3. Exposed database services

- **MySQL (3306)**
- **PostgreSQL (5432)**

If accessible beyond trusted administrative networks, these may allow:

- credential attacks
- database enumeration
- unauthorized data access
- exploitation of weak auth or default accounts

4. Remote administration services exposed

- **SSH**
- **VNC**
- **Telnet**
- **Java RMI**
- **AJP13**

These services are common targets for brute force and known vulnerabilities, especially if default credentials, weak authentication, or outdated versions are present.

5. SMB/NetBIOS exposure on 192.168.56.50

Ports **135/139/445** are heavily targeted on Windows systems and can lead to:

- SMB enumeration
- lateral movement
- remote exploit attempts
- credential relay attacks
- ransomware propagation if vulnerable

6. Potentially dangerous application exposure

- **AJP13 (8009)**: historically associated with Apache Tomcat misconfigurations and vulnerabilities
- **Bindshell (1524)**: very high risk; often indicates an intentionally backdoored or compromised service

- **IRC (6667):** often unnecessary on modern systems and can be abused for botnet or command-and-control if legitimate use is absent
-

Misconfigurations

192.168.56.20

Likely misconfigurations include:

- **Too many services exposed on one host**
- **Insecure legacy protocols enabled**
 - Telnet, FTP, exec, login
- **Unnecessary remote management interfaces available**
 - VNC, X11, Java RMI
- **Database ports reachable on the network**
 - MySQL, PostgreSQL
- **File-sharing services exposed without stated access controls**
 - NFS, SMB, NetBIOS
- **AJP13 exposed publicly or broadly**
- **Presence of bindshell**
 - Strong indicator of a backdoor, test environment, or severe compromise

192.168.56.50

Possible issues:

- SMB/NetBIOS exposed without indication of network restrictions
- May lack segmentation or access control limiting SMB to internal systems only

192.168.56.30

- Minimal exposure, but still should confirm:
 - SSH is key-based, not password-only
 - HTTP is patched and hardened
 - unnecessary services are disabled
-

Recommendations

Immediate actions

1. Investigate 192.168.56.20 urgently

- The **bindshell on 1524** is especially suspicious.
- Treat this host as potentially vulnerable or compromised until proven otherwise.

2. Disable insecure services

- Telnet
- FTP

- exec/login services
- Any unnecessary X11 exposure
- Any unnecessary IRC service

3. **Restrict database access**

- Limit MySQL and PostgreSQL to trusted hosts only
- Block external network access where not needed

4. **Restrict SMB/NetBIOS exposure on 192.168.56.50**

- Allow only required internal systems
- Disable SMBv1 if enabled
- Ensure strong authentication and patching

Hardening recommendations

5. **Use secure alternatives**

- Replace Telnet with SSH
- Replace FTP with SFTP or FTPS
- Use encrypted admin channels only

6. **Close unnecessary ports**

- Reduce exposed services to only those required for business function

7. **Patch and update all services**

- Especially Tomcat/AJP, SMB, SSH, database servers, and web services

8. **Implement network segmentation**

- Separate public-facing, application, database, and administrative services
- Restrict access via firewalls and ACLs

9. **Harden SSH**

- Disable password authentication if possible
- Use key-based authentication
- Enforce MFA where supported
- Limit source IPs

10. **Audit NFS, rpcbind, and SMB shares**

- Verify proper export/share permissions
- Remove anonymous or broad access
- Ensure only required hosts can mount/access shares

11. **Review AJP13 and Tomcat settings**

- Disable AJP if not needed
- Bind AJP to localhost or internal interface only

- Ensure **secretRequired** and connector secrets are configured where applicable

12. Scan for signs of compromise

- On 192.168.56.20, check:
 - suspicious user accounts
 - unexpected listening processes
 - unauthorized cron jobs/services
 - unusual outbound traffic
 - system logs and authentication logs

Ongoing monitoring

13. Enable logging and alerting

- Monitor failed logins, service crashes, and unusual connections
- Alert on access to management ports

14. Perform credential hygiene review

- Rotate potentially exposed credentials
- Remove default or shared accounts
- Enforce strong password policy

Overall Assessment

- **192.168.56.20: High risk / critical exposure**
- **192.168.56.30: Low to moderate risk**
- **192.168.56.50: Moderate risk**, focused on SMB/Windows exposure

The most urgent concern is the breadth of exposed services on **192.168.56.20**, especially the presence of **Telnet, FTP, exec/login, AJP13, and bindshell**. This host should be prioritized for immediate containment, review, and hardening.

If you want, I can also convert this into a **formal vulnerability assessment report** or a **prioritized remediation table**.